

INFORMATION TECHNOLOGY POLICY 2025



IndianOil





Information Technology Policy

Foreword

In today's rapidly evolving digital landscape, Information Technology has become a critical enabler of business efficiency, financial prudence, transparency, and governance. As IndianOil continues its journey towards digital transformation, it is imperative that our IT systems, digital assets, and data are managed in a secure, compliant, and cost-effective manner.

The Information Technology Policy 2025 represents a comprehensive framework that governs the use, management, and protection of IT resources across the Corporation. This policy has been thoughtfully updated to address emerging challenges such as cyber security threats, increasing adoption of digital platforms, and the growing convergence of IT and Operational Technology (OT).

From a financial and governance perspective, this policy plays a vital role in ensuring optimal utilization of IT investments, safeguarding critical financial and business data, strengthening internal controls, and ensuring compliance with statutory, regulatory, and audit requirements. The emphasis on standardized processes, asset management, access controls, vendor oversight, and periodic audits will contribute significantly towards risk mitigation and fiscal discipline.

I truly acknowledge the dedicated efforts and due diligence of all individuals involved in formulating this amended Information Technology Policy Document.

I am confident that this policy will serve as a strong foundation for secure, resilient, and value-driven use of Information Technology, supporting IndianOil's vision of sustainable growth and operational excellence.

I welcome feedback, collaboration, and continuous improvement, so that this policy remains dynamic and responsive to technological advancements and organizational needs.

(Anuj Jain)
Director (Finance)

DOCUMENT CONTROL INFORMATION

DOCUMENT TITLE: INFORMATION TECHNOLOGY POLICY

DOCUMENT NO.: IT Policy 2025

REVIEW FREQUENCY: 24 Months

DISTRIBUTION: All IOCL / Intranet

REVISION HISTORY:

Sl. No.	Author Name	Approver Name	Version Number	Date	Reference	Remarks
1	CISO	ED (I/C) (IS) CO, ED (HRD) CO, ED(CA) CO	1.0	01 st Jan 2017	NA	First Release Issue
2	CISO	ED I/C (IS) CO, ED I/C (HR) CO, ED (CA) CO	1.1	15 th July 2020	COIS/ESECURITY /2020-21/IT Policy-Amnd	Scheduled Review
3	CISO	ED (IS) CO, ED I/C (HR) CO, ED (CA) CO	2.0	17 th Aug 2022	COIS/ESECURITY /2022-23/IT Policy-Amnd	Scheduled Review
4	CISO	ED (IS) CO, ED I/C (HR) CO, ED (CA) CO	3.0	03 rd Sep 2025	COIS/ESECURITY /2024-25/IT Policy-Amnd	Scheduled Review

Index

	Topic	Page No
	Vision and Scope of Policy	3-4
1	Definitions	5-6
2	Network and Infrastructure	7-11
3	Usage	12-14
4	Identity and User Management	15-16
5	Access Policy for System Administrators	17
6	Physical Security	18-19
7	Application Development and Security	20-21
8	Wireless Network Security	22-23
9	Data Privacy and Security	24-26
10	Personnel Security	27-28
11	Business Continuity Plan	29-30
12	Software Compliance and Licensing	31
13	E-mail	32-36
14	Internet Access	37-38
15	Threat and Vulnerability Management	39
16	Security Monitoring and Incident Management	40-41
17	IT Asset Management	42-46
18	Cloud Computing	47
19	Mobile Application and Device	48
20	Open-Source Technology	49
21	Web Hosting	50-51
22	Website Privacy	52
23	Change Management	53
24	Trainees – Student Interns and Summer Trainees	54-55
25	Training	56
26	IT Policy Compliance Audit	57
27	Co-Located Locations	58
28	OT (Operational Technology)	59
29	Data Analytics	60
30	Digital Signature	61
31	DPDP & Legal Statutes	62
32	Aadhaar Usage & Compliance	63
33	Enquiries and Clarifications	64
	Annexure A : Internet Site Restriction Policy	65-67
	Annexure B: Policy for Internet Access by Non-employees (outsiders) and non-officers	68-70
	Annexure-C: Official E-mail Facility	71
	Annexure-D: Aadhaar SOP	72-76

Vision and Scope of Policy

1. Vision

- 1.1. The Information Systems (IS) Group of Indian Oil Corporation Limited shall strive to bring reliable business information on a continual basis to the employees and business partners without compromising data integrity and security of the Corporation through the use of innovative and environment friendly technology, thus promoting corporation's Vision with Values.

2. Scope / Coverage

- 2.1. The purpose of this policy is to ensure secured Information and Communication Technology (ICT) infrastructure that promotes the business needs of the corporation. This policy intends to ensure: -
 - 2.1.1. The integrity, reliability, availability, and superior performance of ICT systems,
 - 2.1.2. That the use of ICT Systems is consistent with business goals of the Corporation,
 - 2.1.3. That ICT infrastructure and Digital asset is used for its intended purpose and
 - 2.1.4. To establish processes for addressing policy violation and sanctions for violators.
- 2.2. This policy is applicable to users in all offices of IndianOil in India and shall operate within the framework of other corporate policies and guidelines issued from time to time.
- 2.3. Requirements of subsidiary and foreign offices shall be handled by respective offices based on needs and local statutory mandatory requirements.
- 2.4. This policy covers both IT and IT security policy. This policy supersedes all previous guidelines and circulars issued to this effect.
- 2.5. This amended policy takes effect from **3rd Sep 2025** and shall be reviewed and approved from time to time by the following three-member committee.
 - a) ED (IS)/ Head of the Department (IS), COIS
 - b) ED (HR)/ Head of the Department (HR), CO
 - c) ED (CA)/ Head of the Department (CA), CO

- 2.6. This policy shall be suitably amended in accordance with IT Act and other regulations passed by Government of India from time to time.

Chapter 1: Definition

1. **Administrator** - Administrators oversee the day-to-day operation of the system and are authorized to determine who is permitted access to particular IT Resource. The responsibilities of the administrator may include installing and configuring system hardware and software, establishing and managing user accounts; managing a multi-user computing environment, such as a local area network (LAN); upgrading software and backup and recovery tasks.
2. **Authorized/Appropriate Use** - IT Resources may be used only for their authorized purposes – that is, to support the business, administrative, and other functions of IndianOil. The particular purposes of any IT Resource as well as the nature and scope of authorized use may vary according to the duties and responsibilities of the User.
3. **IT Resources** - These are servers, personal computing devices, applications, printers, networks (virtual, wired, and wireless), online and offline storage media and related equipment, software, and data files that are owned, managed, or maintained by IndianOil. For example, IT Resources include institutional and departmental information systems, research systems, computer workstations and laptops, the IndianOil's network, and computer clusters.
4. **Sensitive Information** - Sensitive personal data or information of a person/User shall mean information relating to password; financial information (Bank account /credit card/ debit card /other payment instrument details); physical, physiological and mental health condition; sexual orientation; medical records and history; Biometric information and all information prohibited to be disclosed under confidential obligations.
5. **Third Party(ies)** - Persons who are not IndianOil employees, directors, officers, staff. For example, vendors, visitors, business partners etc.
6. **Unauthorized / Inappropriate use** - Anything not Authorized, shall be Unauthorized.
7. **User** - A “User” is any person, whether authorized or not, who makes any use of any IT Resources from any location including but not limited to, all employees, temporary employees, probationers, contractors, vendors and suppliers.
8. **CII - Critical Information Infrastructure** – any ICT infrastructure which, if disrupted, can impact National Economy, National Security, Public Health, Public Safety is classified as CII.

9. ISSC - Information Security Steering Committee, formed as part of the gazette mandate for organisations having Critical Information Infrastructure. The committee is the apex body responsible for the information security policies and controls of the identified CII. The ISSC comprises of following members:
- IT Head or equivalent
 - CISO
 - Financial Advisor or equivalent
 - Representative from NCIIPC
 - Any other expert to be nominated by the organization.
10. ICT - Information and Communications Technologies (ICT) encompasses all technologies for the capture, storage, retrieval, processing, display, representation, organization, management, security, transfer, and interchange of data and information.

Chapter 2: Network and Infrastructure

1. Physical Security: Network and infrastructure facilities shall be secured from any unauthorized access.
2. Redundancy: Critical infrastructure facilities shall be implemented with sufficient redundancy to meet availability requirements.
3. Inventory of Assets and Infrastructure: Inventory shall be maintained for all network and infrastructure devices. All the IT Resources shall be grouped and classified in accordance to the criticality of the information that they transmit, process or store.
4. Network Cabling: Structured cabling shall be used. All network cabling routes shall be documented.
5. Network Diagram: Network diagram shall be maintained. All changes to the network diagram shall be as per change management procedure.
6. Device Configuration: Device configuration for all critical devices shall be documented and reviewed periodically. Any change shall follow change management procedure.
7. Authentication, Authorization and Accounting shall be enabled for Core Switch, Router and Security Equipment.
8. Network Security: Network security shall be established in the data center by means of Perimeter security. At least firewall and IPS shall be in place. In addition, content filter, Gateway Anti-Virus, DDoS protection etc. may be considered as per the requirement.
9. Network Security Zones: Networks shall be divided into multiple network zones according to the sensitivity and criticality of the information or services in that zone. Different zones shall be securely interconnected.
10. Network Traffic Control: Network traffic to outside world shall be controlled by means of web security gateway, content filtering, firewall etc.
11. Network Time Synchronization: All Network, security and Infrastructure devices shall implement Network Time Protocol (NTP) to synchronize time with common source. The identified NTP server should synchronize the time with standard time source set to Indian Standard Time (IST).

12. IPV6 - All new network and infrastructure equipment shall be IPV6 compliant.

13. LAN and WAN

- 13.1. No leased line, MPLS VPN line, Internet line, Point to Point (P2P) communication link and similar such connectivity between locations can be provided without prior approval from COIS.
- 13.2. Based on the needs, line bandwidth enhancement or reduction requirements can be initiated by Divisions and sent to COIS for review and approval.
- 13.3. IP address scheme and allocation for LAN/WAN shall be governed by COIS.
- 13.4. A rate contract (RC) and agency of MPLS service for WAN shall be finalized by COIS for corporation's requirement. Divisions shall utilize this RC for their requirement. For Division's additional requirement, the same RC can be used with prior approval from COIS.
- 13.5. Default settings and passwords shall be changed before deployment of any network and security device. Password to be defined as per password policy.
- 13.6. Secure protocols like SSH, SSL or IPsec shall be used for remote access. Insecure communication protocols like telnet shall be disabled.
- 13.7. Unused ports and interfaces on devices shall be disabled.
- 13.8. Network equipment shall be configured to close inactive sessions.
- 13.9. Only approved routing protocols shall be used for WAN.
- 13.10. Device configuration shall be backed up at least once in a month and whenever there is a change in the configuration.
- 13.11. CCTV should be on a different network zone. And, if required to connect to corporate LAN, the same should be through a security appliance (such as a firewall).

14. Network Access Policy

14.1.

VPN access shall be provided on approval as below -

For Users of	Recommending Authority	Approving Authority of IS Department
Corporate	Officer in Grade 'H' or above	Ref HQ IS Head

Office / IIPM		
COIS	Officer in Grade 'H'	HOD of e-Security
Divisional HQ	Functional Head	Divisional IS Head
Supply Locations / Other Offices	Department Head a. Mkt Div - State Function Head b. Ref Div – Refinery Function Head c. PL Div – PL Region Function Head d. BD – Function Head in BD HQ	Divisional IS Head
Deputation/ Foreign posting	Respective Divisional HR Head	Divisional IS Head

- 14.2. Remote access to corporate network, SAP application, servers and equipment shall be through two factor authentication.
- 14.3. Devices that are used to access the network remotely shall meet the minimum standard for supported operating system, updated antivirus software and web browsers.
- 14.4. Necessary access control shall be used to protect remote as well as local devices from Unauthorized access.
- 14.5. Desktops connected to corporate network shall not be connected to internet through attachment of any modem, mobile, data card or any other such device.
- 14.6. Devices used for connecting to wireless network shall not be permitted to connect to wired network simultaneously.
- 14.7. Access to IOCL Network to be given to only IOCL owned machines with all corporate / divisional approved software installed on the machine. In case network access is required on any machine not owned by the corporation, then the following to be practiced:
 - 14.7.1. Access to be provided only through VPN. Necessary provisions to be made in the VPN access control to allow / deny network resource access as deemed necessary.
 - 14.7.2. In case VPN cannot be used, then the machine on which access it to be given, needs to join IOCL AD and needs to comply with the IT requirements with respect to Cyber Security & Software Compliance - the machine needs to have the same (or similar) applications as being

used at that point in time as the corporation owned machines (such as Anti-Virus, Anti-APT, Auto-Patching etc.). Respective Divisional IS to ensure that the conditions are being met before providing access.

- 14.8. Access to system components by the vendors for support or maintenance via remote access shall be enabled only during the time period needed and disabled when not in use and the access shall be monitored when in use.
- 14.9. For sending data from devices/servers within IndianOil network to external servers on regular or one time basis, to be done after proper approval and assessing all security checks for such connection from Head of business function of the data and IS In-Charge of that server.
15. Infrastructure Change Management: All changes to the network and infrastructure configuration by means of addition of devices, installation of system or upgrade of operating System, software, hardware and firmware shall be done after approval from appropriate authority. All changes to the network and infrastructure shall be documented through formal change management procedure.
16. Extending connectivity to Business Partners
 - 16.1. Network connectivity to business partners shall be provided only on approval from the officer of respective department (Grade 'H' or above) and Divisional IS head.
 - 16.2. The connectivity shall be through secured manner.
 - 16.3. In case of absence of MPLS VPN connectivity, VPN connectivity with two factor authentication can be provided till such time MPLS VPN connectivity is established.
17. Electrical Security
 - 17.1. All servers/critical network equipment shall be supplied conditioned power connection through UPS.
 - 17.2. In the event of a main power supply failure, the UPS shall have sufficient power to keep the network and servers running until the generator takes over or systems can be safely shut down.
 - 17.3. Before installing any new equipment, proper electrical requirements shall be ensured.
 - 17.4. Electrical audit at data centers / server room shall be carried out once in a year. Electrical audit shall be done as per HSE guidelines.

18. Monitoring and Reporting

- 18.1. Logs shall be enabled for all IT security infrastructure / critical servers/ internet facing infrastructure and the same shall be monitored, analyzed and stored for audit purposes. Divisional IS would define the criticality of the servers after taking inputs from application owners.
- 18.2. Logs shall be retained as per applicable GOI guidelines. (Refer to cert-in guideline issued from time to time.

Chapter 3: Usage

1. Acceptable Usage of Information Systems and Assets (IT Resources)

- 1.1. This usage policy shall apply to all Users of IT Resources, including but not limited to employees and approved third parties. This policy is also applicable to privately owned computers when connected to the corporate network.
- 1.2. IT Resources to be used only for their authorized purposes.
- 1.3. Users are entitled to access only those areas for which they have authorization.
- 1.4. The following categories of use are prohibited:
 - 1.4.1. To deny or interfere with or attempt to deny and interfere with services to other Users in any way, including resource hogging, misusing mail list, propagating chain letters, virus hoaxes, spamming (spreading email widely and without good purpose) or bombing (flooding an individual, group or system with numerous or large email message) and distribution of unwanted mail.
 - 1.4.2. Attempts to compromise system security.
 - 1.4.3. Unauthorized access or use.
 - 1.4.4. Disguised use.
 - 1.4.5. Distributing computer viruses, malware and any other malicious software.
 - 1.4.6. Modification or removal of data or equipment.
 - 1.4.7. Use of Unauthorized devices.
 - 1.4.8. Use of Unauthorized and unlicensed software.
 - 1.4.9. Use in violation of corporate contractual obligations including limitations defined in software and other licensing agreements.
- 1.5. Users shall be responsible for maintaining security of their own IT system accounts and passwords. User accounts and passwords shall not be shared.
- 1.6. It shall be the responsibility of the User to back up the data of his/her desktop and notebook.

- 1.7. Corporations reserve the right to check the identification of User using Corporation IT Assets/Services with due approval of Divisional IS Head.
- 1.8. Corporation reserves the right to check the Devices connected to Corporation Network or accessing Corporation data with due approval of Divisional IS Head.
- 1.9. Corporation may deactivate the User access, if the User is found of violating IT Policy with due approval of Divisional IS Head.
- 1.10. Use of the corporate network shall be monitored and audited.
- 1.11. The use of IndianOil's IT Resources in connection with IndianOil's business and limited personal use is a privilege but not a right. The privilege carries with it the responsibility of using IndianOil's IT Resources efficiently and responsibly. Personal use of the IT Resources is permitted provided such use is lawful, does not negatively impact upon the User's work performance, hinder the work of other Users, or damage the reputation, image or operations of IndianOil. Such use must not cause additional cost to IndianOil, for example - Online banking, travel booking, browsing. IT Resources must not be used for private commercial purposes in any circumstance.

2. User responsibility

2.1. General:

- 2.1.1. Users are individually responsible for protecting the data and information in their hands. Security is everyone's responsibility.
- 2.1.2. User shall recognize the criticality of data and take appropriate measures to protect them.
- 2.1.3. Every User must be aware that he/she is accountable for their activities on the system/IT Resource.
- 2.1.4. User shall return the portable storage media, if it is no longer a functional requirement or in case of damage / malfunctioning (or in case of retirement/separation).
- 2.1.5. User shall ensure that portable storage media used is free from virus.
- 2.1.6. User shall ensure that any execution of software from portable storage media is not carried out.

2.1.7. A clear screen policy is recommended to reduce the risk of unauthorized access or damage to media and information processing facilities. All Users of workstations, PCs / laptops are to ensure that their screens are clear / blank when not being used. This may be ensured either by closing the application, or using screen saver utility of the operating system or logging off after using a computer.

2.1.8. Users shall familiarize themselves with legislative requirements which impact the use of IT Resources and act accordingly. IndianOil takes no responsibility for Users whose actions breach laws.

2.2. User responsibility for accessing network

2.2.1. Users shall take prior approval from the competent authority to connect the client system (other than officially issued equipment) to the network.

2.2.2. A client system authorized to connect to one network shall not connect to any other network.

2.2.3. By default, all wireless interfaces shall be disabled on the client system.

2.3. User responsible for accessing logs: User having administrative privilege shall not disable/ delete the audit trails/logs on the client system.

Chapter 4: Identity and User Management

1. Unique identity

Each User shall be allotted unique User id to access network/servers/workstations and systems. Employee number shall be the User id for employees.

Note: For email ids, Email policy under this document to be adhered to.

2. User access management

- 2.1. The lifecycle of the User from the registration of new User to the final de-registration of Users who no longer require access to IT Resources shall be managed through Active Directory.
- 2.2. User ids shall be created for employees joining the Corporation. These User-id are not transferable.
- 2.3. User id once created would not be used again for any other User even if the first id has been deactivated for any length of time.
- 2.4. Role Based Access Control shall be used wherever possible.
- 2.5. Authorizations and default roles shall be attached based on the job profile. The same shall be reviewed by the Head of Department on change of assignment.
- 2.6. Specific roles shall be attached on the basis of approval from respective Head of Department.
- 2.7. User ids shall be deactivated and all roles and authorizations shall be removed on separation of employees from the organization. Any exception shall be based on approval from the Head of Business function.

3. Password Policy

- 3.1. All Users/Administrators shall have a password of at least 8 characters and shall be a combination of alpha numeric/special character.
- 3.2. Passwords shall be changed at regular intervals.
- 3.3. Password must be unique with expiry not more than 90 days.
- 3.4. The last 3 passwords that were chosen by the User shall not be reused.
- 3.5. The desktop/server/laptop shall be locked not beyond 15 minutes of idle period.

- 3.6. Infrastructure supervisor passwords and system supervisor passwords shall be stored in a secure location which can be used in case of an emergency or disaster.
 - 3.7. Default passwords on systems such as database/ servers/switch/routers etc. shall be changed immediately after installation.
 - 3.8. If a password is suspected to have been disclosed/ compromised, it shall be changed immediately, and a security incident shall be reported to the system administrator/ network administrator/ security administrator.
4. Access Control
- 4.1. Endeavors to be made towards no single User having full rights to all system.
 - 4.2. The IS Department shall control network, server and system passwords. IS department will create separate User in end-User department and assign system admin rights to it for maintenance of system in end-User department.
5. Auditing : Auditing shall be implemented on all systems to record login attempts/failures, successful logins and changes made to all enterprise / critical systems and those as deemed necessary by Divisions.
6. User access for Business partners, consultants, advisors, temporary and contract workers
- 6.1. User access for business partners, consultants, advisors, temporary and contract workers, if needed, shall be provided with unique User-id in the Active Directory on approval from officer in grade 'H' or above of the respective department. Naming convention for creating such kind of Users shall be as per e-mail address naming policy defined in E-mail policy.
 - 6.2. User ids shall be created with required authorizations for accessing resources based on the requirement advised by officer in grade 'H' or above of the respective department and approved by IS In-Charge/IS Officer in grade 'H' or above.
 - 6.3. These User ids shall be created with a defined validity period and shall be deactivated immediately at the end of the contract period or upon completion of the approval period or separation due to any reason, and authorizations shall be removed. Any discontinuation shall be immediately intimated by the respective department to IS. Such User ids shall not be deleted or re-used.

Chapter 5: Access Policy for System Administrators

1. Administrator shall implement the security controls specified in the security policies applicable to client systems.
2. The activities specified in the Access Policy for User that require administrator privileges shall be carried out by the system administrator.
3. System administrator shall not attempt any unauthorized use of system/data/programs.
4. System administrator shall be responsible for activities carried out on the client systems, using the administrator account.
5. System administrator shall ensure that client system(s) authorized to connect to one network shall not be connected to any other network.
6. For client systems connected to wireless network, Wireless Network Security Policy shall be followed.
7. Client system(s) shall be hardened as per the relevant procedure for operating system hardening.
8. System administrator shall report security incidents to the security administrator.
9. Client system clock shall be configured as per the Indian Standard Time (IST).
10. Password of the client systems shall be configured as per the Password Policy under Identity and User Management.
11. All activities being performed during remote login session shall be logged and reviewed.
12. System Administrator shall implement end-point security policy as mentioned in the Threat and Vulnerability Management policy.

Chapter 6: Physical Security

1. Information and information processing facilities shall be protected from any kind of compromise, disclosure, modification or theft by ensuring the following controls:
 - 1.1. Critical or sensitive business information and asset shall be housed in secure areas, protected by a defined security perimeter, with appropriate security barriers and entry controls.
 - 1.2. Mechanism shall be in place to protect against hazards or unauthorized access, and to safeguard supporting facilities, such as the electrical supply and cabling infrastructure.
2. Access to the data center/server rooms shall be restricted to the Authorized person only. Delivery and loading area shall be isolated from main data center to avoid any Unauthorized access.
3. Network and security devices shall be housed in network racks.
4. Equipment shall be protected from power failure and other disruption caused by failure of supporting utilities like AC/UPS.
5. All critical IT equipment shall be provisioned for dual mode of power supply.
6. Location-in-charge shall be responsible for providing safety, security, proper upkeep and ambient environment for IT equipment placed at their location (e.g. Air-conditioning, dust/dirt free environment, flood protection measures etc.).
7. Periodic testing and auditing of data center facilities shall be carried out.
8. All equipment shall be covered under insurance as per Corporate/Divisional Policy.
9. CCTV surveillance shall be in place at data center along with recording facility. Recording should be preserved as per guideline from Corporate Security Department.
10. All areas where loading and unloading of equipment are being done, shall be monitored and equipped with the appropriate physical security controls. Access to these areas shall be available only to Authorized personnel.
11. Security personnel at data center shall be properly trained and instructed.

12. Secondary and backup power (using generators) are to be deployed to ensure the continuity of necessary services during power outages. This shall cover all critical applications/ equipment where a downtime is not acceptable.
13. Documents and backups shall be stored in a secured and safe manner in accordance with their classification status.
14. Only authorized personnel shall be permitted to take the equipment which belongs to the Corporation, off the premises. Proper gate pass shall be maintained.

Chapter 7: Application Development and Security

1. In-principle approval shall be obtained by the Division from CO-IS for the following –
 - a. Development of new Software application
 - b. Procurement/renewal of any Software Application license
 - c. Undertaking any new Digital initiative including procurement of underlying Infrastructure
 - d. Procurement of any kind of new IT License/additional license which includes but not limited to Software, OS, DB, Firmware, Virtualization, Network, Security, AI-ML, Data Analytics, COTS Product etc.
2. Application development should be done in a manner to provide seamless access from multiple devices such as mobile, desktop, tablets etc.
3. Development of mobile friendly version, of internet hosted application, like PWA (progressive web application) etc. should be considered while developing software applications.
4. The development of the application should be done preferably in contemporary technologies and should be ready for “cloud deployment” when needed.
5. The platform being used for hosting the application should have enterprise support. “End-of-life” for the same should be 5 years or more.
6. The licensing of the software being used for development needs to be in line with the licensing policy of the OEM.
7. For any application requiring data exchange to and from SAP, SDMS-CRM or any other enterprise -wide application, approval to be obtained from COIS prior to development of software application.
8. Information security shall be incorporated at each level of Software Development Lifecycle (SDLC) such as during requirement analysis, design, development, deployment, maintenance, and improvement.

9. The applications, whether in-house or out-sourced, shall be developed as per secure coding guidelines. For web applications, at least, latest Open Web Application Security Project (OWASP) guidelines shall be followed.
10. For all applications where sensitive data is getting stored, the source code shall be reviewed for vulnerabilities prior to deployment. This would be applicable to both internally and externally developed applications.
11. All applications developed for internal Users shall integrate with Active Directory to authenticate Users.
12. Applications shall have the capability to generate logs of exceptions, errors etc.
13. Changes to the application software during development and maintenance shall be controlled through formal change request form.
14. Vulnerability Assessment and Penetration Testing shall be conducted for all critical applications before deployment and thereafter as per GoI guidelines.
15. A version control system must be used to track and retain information about changes in the source code. The version control system should be able to describe the change, record who made the change, retain the date/time of change, retrieve past versions, and compare versions.
16. Development, quality, testing environment shall be separated from production environment.

Chapter 8: Wireless Network Security

1. User shall use only the corporate wireless connectivity on client systems.
2. Wireless client systems and wireless devices shall not be allowed to connect to wireless access points in un-trusted neighboring premises.
 - 2.1. Separation of wireless LAN from the wired LAN shall be ensured.
 - 2.2. Maintenance and regular audit of wireless access shall be done.
3. Monitoring of uncontrolled wireless devices
 - 3.1. All locations, which are connected to corporate network, where permanent wireless networks are installed shall be equipped with wireless controller to manage access points from a single point and to limit the radio transmission and coverage to the intended area only.
 - 3.2. Simultaneous connection between the wired and any wireless network is not permitted on the same device.
 - 3.3. Wireless network shall be connected to data center through firewall.
 - 3.4. In IndianOil's locations where wireless LAN access has been deployed, wireless intrusion prevention systems shall also be deployed to monitor attacks against the wireless network. The wireless intrusion prevention system shall be integrated with the wireless LAN access system/LDAP/active directory (AD) services wherever possible. In case wireless IPS cannot be deployed (or till such time the IPS is deployed), the access permission to the wireless clients to be provided based on hardware/ mac based white-listing.
4. Authentication of wireless clients
 - 4.1. All access to wireless networks shall be authenticated.
 - 4.2. Corporate password policy must be followed for access to wireless networks.
 - 4.3. The strongest form of wireless authentication permitted by the Access Point/ Wireless Controller device shall be used. For the majority of devices and operating systems, WPA2 with 802.1x/EAP/PEAP or latest shall be used.
5. Encryption
 - 5.1. All wireless communication between wireless client and corporate networks shall be encrypted.

- 5.2. The strongest form of wireless encryption permitted by the client and AP shall be used.
6. Access control policies - Access control enforcement shall be based on the User's authenticated identity, rather than a generic IP address block. This is also known as "identity-based security."
7. Wireless NAC
 - 7.1. Wherever possible, the wireless network shall perform checks for the following client security standards (client integrity checking) before granting access to the corporate network:
 - 7.1.1. All wireless clients must have Anti-Virus software that has been updated and maintained up to the latest patch.
 - 7.1.2. All wireless clients must have security-related operating system patches applied that have been deemed "critical" in accordance with the corporate host security policy.
 - 7.2. Wireless access to be given only to machines logging on to the corporate Active Directory. Any machine, which is not a part of IOC domain shall not be given access.
 - 7.3. Client operating systems that do not support client integrity checking may be given restricted access to the network according to business requirements.
 - 7.4. Local IS may deny/permit the access based on the actual scenario.

Chapter 9: Data Privacy and Security

1. Classification: Information collected, stored, processed and transmitted shall be classified as sensitive based on the definition given in the Data Privacy Policy or any legal statute of the country. Further, based on the inputs received from the data owner, the classification of the data to be done to restrict unauthorized disclosure or modification.
2. Data Security landscape shall be managed as per below -
 - A. For Applications developed/procured by IS and hosted in IOCL Data Centre, Data security shall be managed as per below-
 - Corporate IS/Divisional IS shall be custodian of Business Data and hence, shall be responsible for Data Centre / Network / Application Security.
 - Business function shall be the owner of data and govern any kind of roles/access/authorizations etc.
 - B. For Applications developed/procured by IS and hosted in Cloud/Co-Location Data Centre, Data security shall be managed as per below-
 - Corporate IS/Divisional IS shall be custodian of Business Data and hence, shall be responsible for finalizing scope for Data Centre / Network / Application Security in the Contract.
 - Business function shall be the owner of data and govern any kind of roles/access/authorizations etc.
 - C. For Applications procured by Business function and hosted in IOCL Data Centre, Data security shall be managed as per below-
 - Corporate IS/Divisional IS shall be responsible for providing Data Centre & Network Security platforms.
 - Business function shall be the owner of data and govern Data & Application Security including roles/access/authorizations etc.
 - D. For Applications procured by Business function and hosted in Cloud/Co-Location Data Centres, Data security shall be managed as per below-
 - Business Function shall be responsible for finalizing scope for Data Centre / Network / Application Security in the Contract.

- Business function shall be the owner of data and govern Data & Application Security including roles/access/authorizations etc.

2. Database Management

- 2.1. Default database system passwords shall be changed before putting into production.
- 2.2. Database to be accessed by Authorized Users only.
- 2.3. All User access, queries and actions on databases shall be through applications.
- 2.4. Database administrators shall not have the authority to directly access or query databases. Application data can only be accessed by functional owner.
- 2.5. Database accesses shall be logged and activities of database administrators shall be recorded.

3. Retention

- 3.1. The Document/ data shall be retained as per corporate document retention policy.
- 3.2. However, wherever data is required for longer period due to any ongoing legal issues, the same may be retained as per the requirement of the concerned functional department duly approved by ED/Head Department and Divisional HR Head.

4. Backup - Data backup shall be maintained as per approved business continuity plan.

5. Data Usage - User shall ensure that business sensitive data are being used for its intended purpose only.

6. Disposal - Data shall be permanently erased before any IT Resource or removable media is disposed.

7. Sensitive information such as accounts, files and stored data including, but not limited to, e-mail messages belonging to Users at IndianOil are normally held private and secure from intervention by other Users and shall be accessed only by IndianOil employees, associates, or third-parties (ex. service providers) with signed non-disclosure agreements or designated approved access, with a business need to know. Any distribution of such information internally within IndianOil or outside shall be approved by the Head of Business Function of the department concerned and shall be

through e-mail or other approved electronic file transmission methods only and shall be sent to approved recipients only. Strong encryption is highly recommended. Such information should be stored on a physically secured computer only. Sensitive or confidential information, when printed, should be cleared from printers immediately. When photocopying confidential information, employees are to be careful to remove the original and all copies from the machine when finished. Confidential faxes should contain a paragraph instructing the recipient that the fax is confidential. If received inadvertently, the recipient should notify the administrator/appropriate authority immediately, and not divulge the information.

8. Processing, storage, handling, collection etc. of sensitive data would be governed by the Data Privacy Policy of the corporation. The policy also defined the Sensitive Data.

Chapter 10: Personnel Security

1. IT policy shall be made available to all employees.
2. Only relevant section of IT policy should be shared with third party personnel, if required.
3. Screening to be carried out and NDA (Non-Disclosure Agreement) to be executed with all resident service providers. NDA needs to be signed by service provider, such that the service provider is bound for all acts and omissions of its personnel being engaged for providing services.
4. The service providers shall provide employment verification details and reports for their employees engaged for corporation's work.
5. NDA from all apprentices, summer trainees or any other trainees shall be taken. All such requests for apprentice/ training should come through HR department.
6. Role based training shall be provided to all employees to familiarize them with basic information security principles as per their roles and responsibilities in order to recognize common threats and support security requirements.
7. Processes shall be defined to monitor and review access granted to personnel including temporary or emergency access to any IT Resource.
8. Individuals representing third party organizations such as consultants, trainees, research scholars or any other person who require authorized access to the organisation's information system, shall be identified by the respective department head/location in-charge.
9. All new recruits shall be given Information Security Awareness training.
10. Employees shall be responsible for protecting the sensitive data in their possession e.g. take necessary precautions while working on the data in public places, secure storage of data away from site.
11. Employees shall not indulge in disseminating/ communicating classified information for any other purpose except its Authorized and intended use.
12. Hard copies of sensitive documents which need to be discarded shall be shredded, pulped or incinerated.

13. In case of transfer, the employee shall ensure that all the IT equipment and IT Resource issued by the local IS department are returned to local IS department/custodian of location.
14. Separation / resignation of any employee shall be intimated to IS by HR in advance. In such cases it is to be ensured that all the IT Resource issued by the IS are returned. IS to ensure that their access rights are revoked and their active accounts are deactivated immediately.

Chapter 11: Business Continuity Policy

1. Steering Committee at divisional level shall be formed to oversee the business continuity strategy and business continuity plan (BCP). A working group shall be set up to implement and test the Plans. Divisions shall have their own crisis management plan (CMP) and the Divisions need to publish the Divisional BCP on the respective intranet site.
2. COIS shall maintain the BCP for the applications being hosted at COIS.
3. Risk assessment (RA) shall be done on a periodic basis to treat the identified risks due to threats and disruptions in critical activities.
4. Appropriate controls shall be implemented to prevent or reduce risk from likely disruptions.
5. Business continuity plan (BCP) and incident management plan (IMP) shall be developed to ensure continuity of key service delivery following a disruptive event.
6. Competency in respect to business continuity shall be achieved and roles & responsibility shall be assigned to employees as per their competency.
7. Business impact analysis (BIA) shall be done on a periodic basis to identify priority of recovery of critical activities and its dependency on resources (premises, power and cooling, personnel, technology, hardware, software etc.) and vendors will be determined.
8. Configuration files shall be kept in an offsite location in secured manner.
9. Incident response structure shall be established, managed and reviewed for sufficiency, adequacy and appropriateness.
10. Provision shall be made to manage risks arising out of weaknesses in business continuity arrangement of suppliers and outsource partners.
11. Adequate redundancies shall be created to ensure alternate personnel, location and infrastructure to manage disruption of critical services.
12. Measures shall be implemented to ensure that the security of information and IT Resources containing classified information is maintained to its defined level, even in the event of a disruption or adverse situation.
13. Exercising or testing of relevant plans shall be done on a periodic basis or as and when there is any significant change in architecture. Reports of the same shall be maintained.

14. Relationship with vendors during BCP implementation shall be managed through service level agreement (SLA) and operation level agreement (OLA) and the same shall be reviewed periodically. Vendors shall be regularly updated about scenarios involving BCP executions.
15. Mock drills should be carried out to assess the working of business continuity plan. The mock drill need to be properly recorded and if any issue arises during mock drill same to be assessed and business continuity plan should be modified accordingly.
16. The policy shall be communicated to all the stakeholders.

Chapter 12: Software Compliance and Licensing

1. Software compliance and licensing is an integral and important part of auditing, security and risk management.
2. Procedures shall be implemented to ensure compliance for the use of software in respect of intellectual property rights, and the use of proprietary software products.
3. IS Department shall keep a record of all IT Assets including but not limited to Software applications, Servers, Storage, Databases, COTS Products etc. It will be responsibility of Divisional IS to ensure license compliance.
4. For IT assets procured directly by Business function, it will be responsibility of concerned Business Function to keep record of all such IT Assets.
5. Centralized software for IT asset management shall be installed to the extent possible for tracking hardware and software licenses.
6. Regular audits shall be carried out annually by IS to ensure compliance.
7. All desktops/servers/laptops shall have valid OS license and use only Authorized software.
8. User shall not install any freeware/open-source software without permission of IS dept. IF Any Unauthorized software installed shall be responsibility of the User/owner.
9. Employees who have been provided with Office 365 access can install office 365 till the time he/she is in service

Chapter 13: E-Mail

1. All e-mail account holders have the responsibility to use official e-mail facility in an efficient, effective, lawful, and ethical manner. Use of the IndianOil's e-mail service shall be governed by this policy.
2. User must exercise due discretion on the contents that are being sent as part of the e-mail.
3. Every employee shall be entitled for an official email account.
4. E-mail facility to Workmen shall be provided E-mail facility with outgoing restricted within the organization. In case of outgoing facility to be enabled for outside the organization based on the requirement the same shall be enabled with the approval of Head of Business Function, HR Head & IS In-Charge at Divisional Head Office.

In the event of change of assignment / other reasons, based on the request from user department for revocation of the outgoing facility outside the organization shall be disabled.

5. The consultants and Non-IOCL employees engaged by IndianOil may be provided the E-mail ID on need basis with the approval of Head of Business Function and IS In-Charge at respective Head Office. The E-mail ID to consultants engaged through FTE (Fixed Term Engagement) Policy of Corporation for the duration of engagement. The E-mail ID convention except for regular employees, email display name or ID shall be suitably prefixed with either Consultant/Advisor etc. (e.g. consultant.vijaykumar@indianoil.in), FTE_vijaykumar@indianoil.in for FTE. In the event of end of engagement with the consultant, the User department shall inform the IS Department for de-activation of E-mail ID and email account for the consultant would be disabled. The approval period would be maximum till the end of the financial year or end of engagement whichever is earlier for Consultants and Non-IOCL employees except FTE's. Post that, fresh approval would have to be taken
6. Service (common or shared) email account creation shall be discouraged. These email accounts, when created on specific requirement from any department, shall be approved by the Head of business function and Divisional IS In-Charge.

7. For websites related activities such as Domain name registration / SSL certificate / web administration, a specific email account shall be created as per following naming convention webadminxxxxx@indianoil.in, where xxxxx stands for location code i.e. COIS/PLHO/ RHQ/ MKTHO. This specific mail account shall be used for all website related correspondence including DNS/SSL registration. The access on this e-mail account shall be provided to owner department of respective websites. Similarly, for receiving legal notices, especially under contracts, a service email account (common or shared) to be created. Same shall be created on approval by respective Head of business function and the Divisional IS In-Charge.
8. Any email account shall be owned by an individual.
9. All Official communication shall happen only through official email account.
10. E-mail can be used as part of the electronic file processing in IndianOil.
11. Any e-mail received at official email address, shall not be auto forwarded to any outside domain email address.
12. Auto-save of password in the IndianOil's e-mail service shall not be enabled due to security reasons.
13. Inappropriate use of the e-mail service:
 - 13.1. Creation and exchange of e-mails that could be categorized as harassing, obscene or threatening.
 - 13.2. Unauthorized exchange of proprietary information or any other privileged, confidential or sensitive information.
 - 13.3. Unauthorized access of the services. This includes the distribution of e-mails anonymously, use of other officers' User-ids or using a false identity.
 - 13.4. Creation and exchange of advertisements, solicitations, chain letters and other unofficial, unsolicited e-mail.
 - 13.5. Creation and exchange of information in violation of any laws, including copyright laws.
 - 13.6. Willful transmission of an e-mail containing a computer virus.
 - 13.7. Misrepresentation of the identity of the sender of an email.
 - 13.8. Use or attempt to use the accounts of others without their permission.

- 13.9. Transmission of e-mails involving language derogatory to religion, caste, ethnicity, sending personal e-mails to a broadcast list, exchange of e-mails containing antinational messages, sending e-mails with obscene material, etc.
- 13.10. For sending religious matters, non-business matters.
- 13.11. Willful sending or forwarding material that could be constructed as confidential to such recipients, who are not authorized to receive the same.
- 13.12. Sending or forwarding political, religious, profane, obscene, threatening, offensive or libelous emails.
- 13.13. Use of distribution lists for the purpose of sending e-mails that are personal in nature, such as personal functions, etc.
- 14.** Any case of inappropriate use of e-mail accounts shall be considered a violation of the policy and may result in deactivation of the account. Further, such instances may also invite action by HR under CDA rules.
- 15.** Backup of mails shall be taken by the User at regular intervals. The e-mail administrator shall not restore the data lost due to User's actions.
- 16.** IS shall ensure periodic backup of mailbox database for a period of one year. Retrieval of email data of any user from backup for organizational use needs to approved by Divisional HR head. In case of board member, competent authority for approving such requests shall be Chairman.
- 17.** The backup of any archived emails (saved to local disk) shall be the responsibility of individual user.
- 18.** Each User shall get storage quota on email server as per his/ her grade entitlement as under and manage within the same by archiving old messages periodically:
- Officers : 100GB
 - Workmen : 250 MB – 50GB
 - Service Accounts: 50GB
 - Other accounts: 2GB

The quota limit may be reviewed based on the underlying hardware capacity & capability in case of mailbox(s) hosted at on-premise exchange setup of IndianOil.

In case of workmen, such storage capacity may be increased on need basis with the approval of Head of Business Function, HR Head & IS In-Charge at Divisional Head Office.

For all other cases, such storage capacity may be increased on need basis with the approval of Head of Business Function & IS In-Charge at Divisional Head Office.

In case of mailbox(s) hosted on Cloud, the upper limit on quota is fixed for all users and shall remain unchanged.

- 19.** Only system administrators and officers (grade 'H' or above) shall be authorized to send mass mail on need basis.
- 20.** Officer in grade 'A – G' can send mass mail upto a group of 100 recipients. However, for mass email beyond 100 recipients, request for the same shall be approved by Head of business functions (Officer in grade 'I'). The mails promoting private businesses/commercial/promotional activities should not be sent as mass mail.
- 21.** Broadcast messages shall be kept to a minimum. Any request for sending a broadcast message shall either come from or be approved by an officer not below the level of Grade 'G'. The maximum size of a broadcast message including attachments shall be within 2MB. Company circulars, notifications and policies etc. are excluded from such restrictions.
- 22.** The email accounts of employees on foreign posting and out on deputation to other organizations shall be maintained with mail receive facility only. Separate OU to be created in AD for Deputation out for each division or at corporate level.
- 23.** The email accounts of employees, separating by way of superannuation, voluntary retirement, resignation, death, etc. shall be suspended/de-activated immediately on intimation by HR and retained for a period of 30 days by email administrator.
- 24.** The electronic mail/ archived data stored on corporate infrastructure may be accessed by authorized IS representatives with the consent of concerned Divisional HR head for the following reasons:
 - 27.1 Retrieving business related information from an e-mail account
 - 27.2 Complying with legal/disciplinary requests.
- 25.** Scrutiny of e-mails/Release of logs
 - 26.1 Notwithstanding anything in the clauses above, the disclosure of logs/e-mails to law enforcement agencies by the email administrator would be done only

as per the IT Act 2000 (as amended from time to time) and other applicable laws on the advice of IndianOil management.

- 26.2 The email administrator shall neither accept nor act on the request from any other organization.

26. Audit of E-mail Services

- 27.1 The security audit of email services shall be conducted periodically.

27. Recommendation for sending system generated mails to be given by officer of respective department in Grade 'H' or above and on approval by Divisional IS Head

28. The creation of distribution list or groups in Global address list shall be discouraged except in the cases of requirement covering a wider recipient (above 100). Such requests have to be approved by Functional head and Divisional IS Head and Divisional HR head.

29. The "Litigation on Hold" facility is enabled for Employee E-mail boxes hosted on Cloud where-in the copy of mailboxes is maintained so to enable the availability of information for "Enquiry Proceeding", "Statutory Body", etc. The access to this mailboxes can only be provided with the approval of competent authority Business Function Head, HR Head and IS In-charge at Divisional Head Quarter to which the employee belongs

30. The E-mail facility is now hosted on OEM's Cloud, the access to the Cloud site where E-Mail is hosted shall be provided through Divisional Proxy for accessing E-mail in Desktop PCs allocated for official usage.

For all the facilities requiring approval of competent authority in connection with E-Facility, the decision of ED(IS), COIS shall be final and binding

Chapter 14: Internet Access

1. Internet Connectivity

- 1.1. Divisional headquarters will assess the required bandwidth for their divisional internet requirement and based on it they will take internet connection for entire division.
- 1.2. Provision for clean pipe from ISP may be considered.
- 1.3. Access to internet from corporate network to be provided preferably through centralized divisional internet gateway through proxy servers.
- 1.4. At least, Firewalls and web security gateway shall be used for secure internet connectivity.
- 1.5. Usages logs as per defined policy shall be maintained.
- 1.6. In exceptional cases as per the business need, separate broadband/data card-based internet connectivity may be provided after taking due approval from IS In-Charge at locations. Such endpoints which are directly connected to internet shall not be part of IndianOil network.

2. Internet Access

- 2.1. Usage of internet on company provided networks are intended for business purposes and knowledge enhancement only.
- 2.2. All Officers will be provided with internet access. Internet access for staff / non-IOCL employees working on IOCL machines shall be provided on need basis and will follow procedure given in Annexure-B. For access on personal / non-IOCL devices, refer to the external network access clause.
- 2.3. Cookies and running of active content, such as, ActiveX, JSP, PHP etc. should be allowed from the trusted sites only.
- 2.4. Defined access rules depending on the nature of job requirement shall be there.

3. Users to ensure that copyright and other intellectual property issues are not being violated by any of their activities.
4. The files downloaded from the internet or accessed from the portable storage media should be scanned for malicious contents before use. To ensure integrity of the downloaded files, digital signatures/hash values should be verified wherever possible.

5. Before accepting an SSL certificate, the User should verify the authenticity of the certificate.
6. The User should log-out from web-based services, like web mail, before closing the browser session.
7. After completing the activity in the current web-based application, the browser session should be closed.
8. All other points of Internet usage shall be governed by the policy given in Annexure-A.

Chapter 15: Threat and Vulnerability Management

1. Threat assessment – Regular vulnerability assessment of critical network and security devices shall be carried out to identify vulnerabilities and weaknesses associated with configuration, use of ports, protocols, services etc. VA/PT of the critical IT infrastructure shall be done as per applicable government guidelines. However, third party VAPT shall be done for internet facing equipment/applications at least once in a year or whenever there is a major change.
2. Integration with external intelligence – The organization shall establish a formal relationship with external entities for receiving timely notification on emerging threats, vulnerabilities, bugs and exploits. External sources may include vendors, trusted third parties, OEMs, open-source communities, industry bodies and other relevant organizations.
3. System hardening – System hardening guidelines and best practices shall be followed for IT assets like servers, desktop, network, security equipment etc.
4. Perimeter threat protection – Multi-layer security devices and best practices shall be followed to ensure perimeter threat protection for corporate network.
5. Protection from fraudulent activity – Adequate protection shall be deployed to block fraudulent applications such as key loggers, phishing, identity theft and other similar applications.
6. End-point security – All end points shall have corporate Anti-Virus installed with latest signature (which are to be updated regularly). Only required services shall run on the end point devices. Any other services running on the end point devices / systems to be blocked through various methods/technologies. The User shall not have administrator (even local) privilege access.
7. Remediation – All IT Resources to be updated with latest security patches and signatures.

Chapter 16: Security Monitoring and Incident Management

1. The security monitoring and incident management policy in organization shall cover the following broad points:
 - 1.1. The incident management requirements shall be based on compliance requirements, business criticality and security threat to the corporation.
 - 1.2. An inventory of all critical information sources shall be created which generate useful log information for detection of security events or incidents.
 - 1.3. Incident management system shall be in place to take care of the IT security incidents of the corporation.
 - 1.4. Critical security incident shall be notified to the respective regulatory authority, if required.
 - 1.5. Integration of incident management function with the log management system, security intelligence mechanism and infrastructure management processes shall be done.
 - 1.6. An enterprise log management system shall be defined that specifies architecture for log collection and management processes for log management and policies for logging, monitoring and auditing.
 - 1.7. Log archival, retention and disposal measures shall be deployed as per the compliance requirements for the corporation.
 - 1.8. Process shall be established for regular review and analysis of logs and log reports.
 - 1.9. It shall be ensured that a significant visibility exists across the organization over the likely incidents, reporting incidents and incident management capabilities of the corporation.
2. Security Incident Management
 - 2.1. Repository of incidents that are relevant to the organization's environment shall be created based on the historical information and threat landscape.
 - 2.2. Categorization of incident shall be done at divisions based on its criticality for prioritization of incident's response, arranging proportionate resources, and defining SLAs for remediation services.

- 2.3. Division shall maintain guidelines for prioritization of incidents response. The same shall be established based on the criticality of affected resources and potential technical and business effects of such incidents.
- 2.4. Incident management plan shall be in place for all incident types.
- 2.5. Roles and responsibilities for incident management process shall be clearly defined and documented.
- 2.6. Significant level of efforts shall be dedicated for spreading awareness of incident response process throughout the corporation.
- 2.7. There shall be a defined and established escalation process for response requirements.
- 2.8. Significant level of collaboration shall exist with internal (security function, infrastructure management, application support) and external stakeholders (threat advisory, vulnerability and exploit databases, vendor alerts and computer emergency response teams).

Chapter 17: IT Asset Management

1. Interdependence of systems – Replacement/ addition of any IT asset with newer/upgraded version shall be done after both forward and backward compatibility analysis with existing infrastructure devices.
2. All IT assets like hardware, peripherals, networking and security components, software and media etc. shall be suitably insured for fire, theft, natural calamity etc. as per divisional policy. Standard Operating Procedures (SOP) shall be developed, maintained and reviewed to support the IT operations.
3. Asset information verification shall be done on yearly basis or in case of any major changes.
4. Asset Labeling and Handling
 - 4.1. Asset register shall be maintained by IS department for all IT assets procured by IS department. Other department may buy IT assets in consultation with IS department for use in their projects. However, assets procured by non-IT departments shall not be recorded in asset register of IS dept.
 - 4.2. Asset Register shall be maintained which includes the following information about an asset:
 - 5.2.1. Asset ID: A unique asset identification number assigned to each asset for easy and quick identification.
 - 5.2.2. Asset name: Name given for identification of asset based on its functionality.
 - 5.2.3. Asset details: Details about the asset such as IP address, MAC address, host name and software license number etc. wherever applicable.
 - 5.2.4. Serial No. / License: In case of hardware provide serial number and for software provide license key.
 - 5.2.5. Purchase Order No., date and cost of equipment.
 - 5.2.6. Warranty/ AMC: Provide details for warranty / AMC validity date.
 - 5.2.7. Asset Type: Hardware/ software/appliance etc.
 - 5.2.8. Physical Location: Physical location and details where the asset is located.
 - 5.2.9. Owner: Person who is responsible for the asset.

5.2.10. Custodian: User who is assigned the asset for the operations.

5.2.11. Asset Class: Class of Asset – “Critical” or “Non-Critical”

Asset information should be captured using asset register template (Table-A).

5. Procurement

5.1. All purchases of new systems and hardware or new components for existing systems must be made in accordance with IT policy.

5.2. The Procurement process shall be followed as per the corporation’s approved procedure. If any IT asset is procured by any department other than IS, then it is responsibility of concerned department to maintain the inventory and comply all licenses and legal issues involved with that asset. The inventory of the assets to be provided to local IS department.

5.3. Any ULA (Unlimited License Agreement) should be executed on COIS approval.

6. Maintenance

6.1. COIS shall finalize rates and agency for annual maintenance of all IT hardware and networking equipment procured/ maintained by IS department. However, separate agency may be engaged by divisions for specialized equipment procured/ maintained by respective IS Department.

6.2. Regular monitoring (console) of patch management and antivirus update shall be managed at divisional level. If required, separate agencies may be engaged by local IS for facility management services (FMS) comprising of – regular monitoring (console) of patch management, antivirus updation, network traffic/bandwidth management and liaising, system administration of firewall, proxy, content filter, anti-spam device, all server/system administration etc.

7. Obsolescence

7.1. Desktops / Laptops / Servers / Printers / Monitors / Routers /Switches and other IT related peripherals shall fall in the category of obsolete item which are either:

Phased out by the manufacturer (reached end of life-EOL).

OR

They do not support technical advancement like higher/newer version of SAP GUI, operating system (OS), system software, application software etc. that is likely to affect the business/ operational requirement of the corporation adversely.

OR

The equipment is beyond repairs (as certified by the AMC partner/OEM).

OR

If security updates/patches are not available for the device.

OR

Main components of the equipment e.g. CPU, RAM, HDD, controller cards, SMPS, main circuit boards etc. are no more available in the market.

7.2. In case of replacement of obsolete item with new equipment, buy-back option shall be explored.

7.3. The required disposal procedure such as administrative approval, write off approval etc. are to be followed as per corporate procedure. However, decision to declare obsolete item is to be taken in consultation with respective unit IS head.

8. Hiring

8.1. Necessary IT equipment shall be hired for exceptional reasons like training, urgent replacement in lieu of breakdown of server etc.

8.2. Hiring shall not be used to fulfill the permanent shortage of IT equipment.

9. Experimentation of Technology

9.1. To keep itself abreast with the changes in technology and take decision on adoption of the same. COIS/ Divisional IS may procure IT equipment on experimental basis for use.

9.2. After evaluation, divisional IS shall give its report to COIS on usefulness of the technology.

9.3. Any new business initiative which requires augmenting IT infrastructure / services / linkage to IOCL network / software procurement / software development would need approval of COIS.

10. Hardware

10.1. Allotment/Distribution

10.1.1. In Co-located offices where officers belonging to different divisions / offices are positioned, IS infrastructure shall be provided by related IS department which has been assigned responsibility for providing IS infrastructure services in particular building / office.

10.1.2. PC – One PC per seat for officers. If there are 3 officers coming in shifts for the same job, they shall share one PC but use their own login ID, not

common User login ID. Allocation of PC for staff shall be approved by the HOD/Functional head.

- 10.1.3. Resident business associates may be provided with PC on approval of Head of business function.
- 10.1.4. Laptop – Allocation shall be on need basis on approval of Head of business function. The User department shall be the custodian.
- 10.1.5. Printers/Scanner – Use of shared laser printers/Printer-cum-scanner on LAN shall be encouraged. Individual printers can be given only to the officers on need basis in exceptional cases. For such types of cases approval need to be obtained by officer of respective department (Grade 'H' or above/HOD).
- 10.2. On exceptional basis and where need exists, memory and storage capacity can be increased for individual PCs and notebooks. Such proposal needs approval of officer of respective department (Grade 'H' or above/HOD) in consultation with unit IS In-Charge.

11. Software

- 11.1. All Desktops/servers/laptops shall have licensed and authorized software.
- 11.2. All SAP software licenses shall be procured centrally at COIS and shall be distributed as per requirement.
- 11.3. Antivirus and asset management software shall be standardized throughout the corporation. COIS shall line up rate contract for the same and based on rate contract divisions shall procure the software.
- 11.4. Office automation software – MS Office: Agency and rate contract for licenses shall be finalized by COIS for bulk requirement.
- 11.5. In-principal approval shall be obtained from COIS for procurement of any new software/ applications/ Systems in case the software shall be deployed across the location / division / corporation or shall require additional resources in terms of corporate network / security / Licenses. Divisions shall maintain the inventory of software / applications / systems for their divisions.
- 11.6. Disposal: Adequate measures shall be taken to prevent misuse of obsolete media and licenses.
- 11.7. Redistribution:
 - 11.7.1. Whenever a PC or a server or a hard disk is replaced or reallocated, all User generated documents, images and files shall be removed before reallocation, the responsibility for ensuring this shall be borne by the individual whose PC has been replaced, in coordination with the engineer who moves that person's data to the new machine.

- 11.7.2. A replaced machine shall also have all installed software removed before re-distribution. Such machines should be formatted before redistribution.
- 11.8. Inventory of all the authorized software and licenses procured by IS department must be maintained by respective IS department. It will be responsibility of Divisional IS to ensure license compliance.
12. Consumables – Consumable like cartridges, CDs, DVDs, pen drive, USB HDD, Tag/Card reader (USB), Proximity card etc. shall be treated as stationary items and shall be procured by concerned department accordingly.
13. Disposal of e-waste – Disposal of e-waste shall be done as per HSE guidelines and material management manual.

Table A – ASSET REGISTER

S. No.	Asset ID	SAP Asset No.	Asset Name	Details	Class of Asset	Serial No./ License No.	PO No., date and Cost	Warranty / AMC	Valid up to date	Asset Type	Asset Location	Asset Owner	Asset Custodian	Remarks

Chapter 18: Cloud Computing

1. For any update or refresh of the existing IT infrastructure or for a new requirement, it is advisable to explore the possible options on Cloud first. Thorough assessment of the nature of the work to be done, data to be handled, applications to be moved etc. to be carried out and based on the assessment, the services on cloud may be adopted.
2. Necessary cyber security requirements and compliance to the statutory data regulations (specifically with regards to residency / localization of the data) to be ensured.
3. For any cloud service, only MeitY empaneled CSP (Cloud service providers) to be engaged. The list of the empanelment is available on the MeitY website.
4. Any engagement requiring sensitive personal data or information needs to be thoroughly examined and strict security controls such as encryption of data (both at rest as well as motion), multi-factor authentication etc. to be ensured.
5. For projects involving Aadhaar data to be stored on cloud, compliance to the Aadhaar related regulations (as per Aadhaar Act or other existing statutes) to be ensured. Aadhaar related technical requirements to be built into the contract.
6. Any network communication link to the CSP needs to be taken on approval from COIS.

Chapter 19: Mobile Application and Device

The term “Mobile Technology” have very wide representation. Adoption of mobile technology means enabling User to access corporate applications and data while on move from anywhere and anytime by deploying corporate mobile application.

1. Mobile Applications

1.1. Types of Mobile Application: IndianOil had adopted and will continue to adopt new technologies and leverage the same for achieving business goals. Customized mobile applications in IndianOil are divided, but not limited, into the following categories:

1.1.1. Mobile Application for Employees.

1.1.2. Mobile Application for Dealers, Distributors and Consumers.

1.1.3. Mobile Application for General public.

1.1.4. Mobile Application for Vendors.

2. Development Architecture

2.1. The architecture shall be based on industry-wide open standards so as to offer integration and interoperability with third party tools and software.

2.2. SAP Net Weaver Gateway/ SAP PO shall be used to exchange data with SAP system.

2.3. For external Users SSL connectivity shall be established between internet/intranet devices and web servers using public certificates signed by certifying Agency (CA).

2.4. Standard User Interface (UI), look and feel (color combination, icons, background graphics etc.) for all mobile applications shall be followed.

3. Mobile Device Security

3.1. In order to prevent unauthorized access, devices shall be password protected using the features of the device and a strong password as per corporate policy shall be used to access the corporate network.

3.2. The device shall lock itself with a password or PIN if it's idle for longer periods.

3.3. Rooted (Android) or jail broken (iOS) devices are strictly forbidden from accessing the network.

Any new mobile application to be developed has to be In-principally approved by COIS

The Mobile Application to be developed has to adhere to the Mobile Application Development Framework that will be approved and maintained/updated by COIS from time to time.

Chapter 20: Open-Source Technology

1. Integration of open-source technology with existing infrastructure such as OS, processing power, storage space, connectivity, interoperability with other technologies should be thoroughly evaluated for security vulnerabilities and compliance with organization's specific needs.
2. All open-source products installed and in use, shall be secured and kept updated by installing latest patches and upgrading to latest version as and when they are released.
3. Subscribe to respective open-source security announcement mailing list to get patches, bug fixes and software upgrades at regular intervals. Periodic auditing of the open-source products like commercial software is to be carried out.
4. In case of vendor providing open-source technology, adequate support in the form of upgrades, patches etc. must be a part of contractual agreement.

Chapter 21: Web Hosting

1. All websites shall be hosted in-house or NIC or any other server owned by Government of India or the State Government or with a third-party organization's servers located in India or as per prevalent guidelines on subject issued by Govt. of India.
2. New domain name registration shall be done after in-principal approval from COIS. Renewal of existing domain name shall be the responsibility of respective domain owner. New domain name registration shall be preferably done in ".in" registry and under SLD (second level domain name) ".indianoil.in" e.g. refinery.indianoil.in.
3. CERT-In guidelines, GoI guidelines on websites and application security guidelines shall be followed.
4. Application security audit shall be carried out by CERT-In empaneled vendors before the site is made operational or after any major change and vulnerabilities should be mitigated.
5. PT (Penetration Testing) shall be carried out by CERT-In empaneled vendors before the site is made operational or after any change in source code and vulnerabilities should be mitigated.
6. The website hosting IT infrastructure should be ISO 27001 compliant. VA (Vulnerability Assessment) for this infrastructure shall be carried out by CERT-In empaneled vendors yearly and vulnerabilities should be mitigated.
7. System shall be in place to carry out VA/PT at least once in a year or during any major changes.
8. The operating system, web server and other applications on the servers being used shall be patched with the latest security updates available from respective OEMs.
9. A dedicated network zone shall be created for the servers hosting the website.
10. The network access to such zone shall bear a "Deny all, allow selected" access policy.
11. Database server process shall run with minimum privileges and never as administrator. Audit trail logs on Database server shall be enabled.
12. Database server should never be accessible on public IP. Database server access should be only allowed from Web server through particular port only.

13. Sensitive information between the browser and the web servers shall be encrypted using a public/private key pair and it should be traceable to root CA.
14. All web servers hosted in public domain should have latest version of SSL certificate from trusted authority.
15. Monitoring and early alert mechanisms shall be in place to detect and inform defacement, intrusions and exploits on the website.
16. If required, disaster recovery/business continuity for the website shall be in place.
17. In case of website being outsourced, security requirements as above shall be clearly mentioned in the contract.
18. The change management process for the website shall be documented and approved by competent authority.
19. Acceptable use policy and privacy policy for the website shall be mentioned on the website.
20. Log files should be regularly archived, stored and analyzed.
21. Maintain latest copy of web site content on a separate secure host or media.

Chapter 22: Website Privacy

1. The purpose and usages of the data (Users' data/ cookies) being collected shall be mentioned in the website.
2. IT Act 2000 along with its subsequent amendments from Government of India shall be followed.
3. All legal statute, as applicable, such as Aadhaar Act shall be complied with in all application/websites capturing, storing, processing Aadhaar data.
4. If website is using links to other websites, it shall be informed to visitors that corporation is not having any control on externally linked websites and if third-party is providing any information on external websites, corporation is not responsible for its security and use.
5. All IOCL public websites to host the corporation's Data Privacy Policy.

Chapter 23: Change Management

The primary goal of the IT change management process is to accomplish IT changes in the most efficient manner while minimizing the business impact, costs, and risk.

1. Formal change request—There shall be a formal change request duly approved by system/software owner.
2. Document change request - All requests for change shall be documented. The completion of a new request for change shall be completed by the change coordinator with input from the change requester.
3. Categorize and Prioritize the Change - The change coordinator will assess the urgency and the impact of the change on the infrastructure, end-User productivity and budget to prioritize the same.
4. Analyze and Justify the Change –Request shall be assessed by the change coordinator to identify how the change may impact the infrastructure, business operations, and budget. When completing the analysis of the change, the change coordinator shall ensure they consider the business as well as the technical impacts and risks.
5. Approve and Schedule the Change—Request for change shall move to competent authority for approval or rejection of the change.
6. Plan and Complete the Implementation of the Change - This process includes developing the technical requirements, reviewing the specific implementation steps and then completing the change in a manner that shall minimize impact on the infrastructure and end-Users.
7. Take backup of existing system/configuration before applying Changes - Before implementing the change, backup of existing configuration must be taken and then the changes should be implemented.
8. Post-Implementation Review - A post-implementation review shall be conducted to ensure whether the change has achieved the desired goals. Post-implementation actions include deciding to accept, modify or roll back the change, contacting the end User to validate success and finalize the change documentation.

Chapter 24: Trainees – Student Interns and Summer Trainees

1. Student Interns (This section of policy is applicable for Marketing Division only)
 - 1.1. The IS, Head at HQ / SO/ RO having IS Departments can engage student interns from reputed Technical / Educational Computer Institutions eg NIIT, Aptech, CMC.
 - 1.2. However, any such engagement has to be through the respective HR Department and the Training Department shall control these trainees / interns etc.
 - 1.3. The Student Interns may be selected for a period of 12 months and the number of such student interns would be decided by the IS Head, Marketing Division based on work requirements.
 - 1.4. The student interns will be associated in software development, computer center, network, database, security management and User support. The student interns will be paid a monthly stipend in line with the stipend paid to CA interns. Necessary budget is to be provided in the revenue budget by IS department.
 - 1.5. The student interns will be selected by a committee consisting of officers from IS, Finance and HR and will be approved by Region/State Heads for RO / SO and by IS Head at HQ. The process for their selection would be:
 - 1.5.1. Reputed Technical / Educational Computer Institutions would be requested to provide resume of interested students.
 - 1.5.2. The students would undergo written test followed by interview by the nominated committee.
 - 1.5.3. Students would be offered internship based on the merit list. In case a student in merit does not join, the seat would be offered to next student in merit list and so on.
 - 1.5.4. ER/IR department will issue the letter of engagement on behalf of IS group.
2. Summer Trainees (This section of policy is applicable for all the Divisions)
 - 2.1. Students pursuing engineering degree in Computer science / Computer engineering/ Information Technology related courses can be taken as summer trainees to fulfill their curriculum needs.

- 2.2. Acceptance and selection of these students shall be done by respective training departments. Each student shall be allotted one guide/ mentor from IS Department. Each student shall be given a project as per his need. No stipend shall be paid to these summer trainees.
- 2.3. Training Departments shall supervise the progress of the student with periodic review.
- 2.4. At the completion of the project, based on the inputs given by the concerned IS department, training department shall issue necessary certificates for submission to the college.

Chapter 25: Training

1. Divisional IS shall draw its annual training calendar in consultation with divisional training department and share it with other divisions. This calendar shall consist of User training and skill up-gradation training for employees from IS department. Any employee can be nominated across divisions for relevant training.
2. Employees from other departments can be nominated for IS related training. This shall be approved by respective IS In-Charge.
3. IS In-Charge can nominate any employee for outside seminar and training & certification as per training policy of the respective division such approvals shall be routed through respective training departments in consultation with IS department.
4. IS In-Charge can nominate any employee for outside seminar and training which does not require any subscription, such nomination shall not need approval from training department.
5. Before adoption of any new technology, necessary training shall be imparted to the related IS personnel.
6. User training shall be conducted on regular basis about awareness of e-security, IT practices and IT Policy.

Chapter 26: IT Policy Compliance Audit

1. There shall be an appropriate system of audit, which provides an independent assessment of effectiveness of IT policies within the corporation.
2. To execute the audit, an inter-divisional audit team comprising of IS persons headed by officer in Grade 'F' or above from COIS. Compliance reports/documents based on this audit shall be formulated.
3. The audit to be carried out at least once a year.
4. The audit report along with the ATR from respective Divisions to be submitted to Corporate IS. The report to mention deviations, if any, and proposed amendment with target dates.

Chapter 27: Co-Located Locations

All IT services & support to be provided by the location having established infrastructure in vicinity irrespective of the IOCL officer division (co-located offices).

Chapter 28: OT (Operational Technology)

1. Operational Technology (Industrial Control Systems / SCADA / DCS / TAS/Carousel Monitoring Systems etc.) is to operate on a separate network than the IT network (Office/ Corporate LAN).
2. The interface points between OT & IT to be clearly identified and connected through a security appliance. Only the requisite connections to be allowed through the interfacing appliance.
3. OT systems should not be directly connected to Internet.
4. Any connection between OT and IT networks is to be allowed only on explicit approval from the respective functional department (Officer in Grade 'H' or above at HO/HQ Level) and Divisional IS head.
5. No data from OT networks to be sent outside IOCL without an explicit permission of the respective functional head at the HO/HQ level.
6. For data transfer from any OT network of identified CII (Critical Information Infrastructure) location to outside IOCL, the permission needs to be sought from ISSC (Information Security Steering Committee). The list of CII shall be maintained by COIS and shared with Divisions.
7. Divisions to ensure Cyber risk assessment is carried out at least once annually for any data transfer to and from OT systems. Wherever mandated by any statute, the cyber risk assessment to be carried out in compliance with the guidelines / requirements of the statute.
8. Divisions to conduct audit of all firewall / interface points at least once annually.
9. VPN connections to the OT systems should always be under supervision of IOCL officer.

Chapter 29: Data Analytics

1. Identification of Use Cases, for Enterprise Data Analytics, shall be jointly undertaken by the Requesting group, COIS and Divisional IS.
2. The existing Enterprise Systems (Transactional Systems) have respective analytics platform associated with them namely:

Enterprise Systems (Transactional Systems)	Associated Analytics Platform
SDMS-CRM	CRM BI and Customer Loyalty and Analytics Platform (CLAP)
SAP-ERP	SAP Business Intelligence Warehouse, Anvaya and other Reporting tools
IRAS	Vishleshan (Retail Analytics)

3. Identified Analytics use cases pertaining to above Enterprise Systems shall be developed on the respective analytics platforms / systems. The requirement for Data from the above-mentioned Enterprise Systems shall be met from the associated Analytics platform.
4. Data extraction directly from Enterprise Systems (Transactional systems) for Data Analytics shall be discouraged.
5. For Data Analytics, involving more than one Enterprise systems and / or requiring data from systems across divisions, Data Management Platform (DMP) shall be used. Data requirement and modalities shall be approved by **respective** head of requesting department, Respective Divisional IS, ~~SIS~~ and COIS.

Chapter 30: Digital Signature

1. Digital signature, for official use, to be procured on approval by respective department (Officer in Grade 'H' or above).
2. Use of digital signature for new business processes to be approved by functional department (Officer in Grade 'H' or above).
3. The life cycle of the digital signature from procurement to retiring to be managed by respective business function/department.
4. Digital Signatures to be maintained centrally at COIS for application based digital signing.

31. DPDP & Legal Statutes

Digital Personal Data Protection Bill is to be strictly adhered to when “Personal Data” is being collected / stored / processed either directly or through other means.

Necessary conditions pertaining to DPDPA liabilities (penalties) should be mentioned in contracts with agencies who are engaged to collect / process / store personal data from any customer / partner of IOCL.

32. Aadhaar Usage & Compliance

All systems and applications operating within IndianOil or to be developed in future and utilizing services of UIDAI namely eKYC etc. or services as per the roles of Authentication Service Agency (ASA), Aadhaar User Agency (AUA) or KYC User Agency (KUA), must adhere to the compliance requirements detailed in the "Aadhaar Compliance and Security Annexure-D". This annexure is subject to periodic review and immediate updates in response to changes in regulatory frameworks such as the Digital Personal Data Protection (DPDP) Act, the Aadhaar (Targeted Delivery of Financial and Other Subsidies, Benefits, and Services) Act, 2016, any statutory requirements from government or regulatory bodies, or any new directives issued by the Unique Identification Authority of India (UIDAI) to ensure ongoing compliance.

All application owners must make endeavor to comply with the procedures and practices as laid out in **Annexure D** from time to time. “

Chapter 33: Enquiries and Clarifications

For clarifications on this policy, and enquiries, please contact:

Designation – Chief Information Security Officer (CISO),
Corporate IS Department

Annexure-A: Internet Site Restriction Policy

All the filtering appliance/software works based on global category of the site which is decided on certain parameters. The sites may be Monitored/ Blocked on the category mentioned below. However, based on usage pattern and threat perception the monitoring and blocking action for the category may be changed by the authorised IS-security personal.

Site Category	Monitor	Block
Abortion		
Pro-Choice		B
Pro-Life		B
Adult Material		
Adult Content		B
Lingerie and Swimsuit		B
Nudity		B
Sex		B
Sex Education		B
Advocacy Groups		
Bandwidth		
Internet Radio and TV		B
Internet Telephony	M	
Peer-to-Peer File Sharing		B
Personal Network Storage and Backup	M	
Streaming Media	M	
Business and Economy		
Financial Data and Services	M	
Drugs		
Abused Drugs		B
Marijuana		B
Prescribed Medications	M	
Supplements and Unregulated Compounds	M	
Education		
Cultural Institutions	M	
Educational Institutions	M	
Educational Materials		
Reference Materials	M	
Entertainment	M	
MP3 and Audio Download Services		B
Extended Protection		
Elevated Exposure	M	
Emerging Exploits	M	
Potentially Damaging Content	M	
Gambling		B

Games		B
Government		
Military	M	
Political Organizations		B
Health	M	
Illegal or Questionable		B
Information Technology		
Computer Security	M	
Hacking		B
Proxy Avoidance		B
Search Engines and Portals	M	
URL Translation Sites	M	
Web and Email Spam		B
Web Hosting	M	
Internet Communication		
General Email	M	
Organizational Email	M	
Text and Media Messaging	M	
Web Chat	M	
Job Search	M	
Social Media	M	
Militancy and Extremist		B
Miscellaneous		
Content Delivery Networks	M	
Dynamic Content	M	
File Download Servers	M	
Images (Media)	M	
Image Servers	M	
Network Errors	M	
Private IP Addresses	M	
Uncategorized	M	
News and Media	M	
Alternative Journals	M	
Productivity		
Advertisements		B
Freeware and Software Download	M	
Instant Messaging	M	
Message Boards and Forums	M	
Online Brokerage and Trading	M	
Pay-to-Surf		B
Racism and Hate		B
Religion		
Non-Traditional Religions and Occult and Folklore		B
Traditional Religions	M	
Security		

Bot Networks		B
Keyloggers		B
Malicious Web Sites		B
Phishing and Other Frauds		B
Potentially Unwanted Software		B
Spyware		B
Shopping		
Internet Auctions	M	
Real Estate	M	
Social Organizations		
Professional and Worker Organizations	M	
Service and Philanthropic Organizations	M	
Social and Affiliation Organizations	M	
Society and Lifestyles		
Alcohol and Tobacco		B
Gay or Lesbian or Bisexual Interest		B
Hobbies	M	
Personals and Dating	M	
Restaurants and Dining	M	
Social Networking and Personal Sites	M	
Special Events		
Sports	M	
Sport Hunting and Gun Clubs	M	
Tasteless	M	
Travel	M	
Vehicles	M	
Violence		B
Weapons		B

Annexure-B: Policy for Internet Access by Non- IOCL employees (outsiders) and Non-officers IOCL employees

The facility of Internet access to non-IOCL Users (outsiders) and to IOCL staff (non-officers) should be given ONLY on need basis. The need to be assessed by the department/function concerned, with which the said person(s) is/are attached. The approval process is proposed to be as follows:

1. For non-IOCL employees (on-IOCL parties e.g. Consultants/ Advisors/ Retainers, Auditors, Helpdesk Engineers, CISF personnel, IT Support staff etc.)
 - 1.1. Proposal – Concerned function/department with which the particular person is attached should initiate the proposal for the Internet facility to be given to a particular person belonging to this category (Auditor, CISF, Retainer, Consultants, advisors etc.) justifying the reason.
 - 1.2. Approval – The proposal must be approved by officer of respective function (Grade 'H' or above) and Unit IS Head.
 - 1.3. Validity – Such Internet access facility shall by default be valid till end of financial year or end of engagement whichever is earlier. The same needs to be renewed after expiry of validity depending on the need. The renewal procedure to follow same as original approval.
 - 1.4. Revocation – Requestor/forwarding department shall be responsible for initiating internet revocation request.

Approving Authority Table (Outsider: Non- IOCL Employee)

For outsiders (Non-IOCL employee) of	Approving Authority in Functional Department	Approving Authority in IS Department
Corporate Office	Officer (Grade 'H' or above)	IS Head (Refineries)/ Officer (Grade 'H' or above) at RHQ-IS
COIS/Divisional HQ		IS Officer (Grade 'H' or above) in COIS/ Divisional IS Head
Other offices/location		IS Head (Refinery / State Office/ Regional Office/ Business Dev. / IIPM)

2. For staff (non-officers IOCL employees)

- 2.1. Proposal - Concerned function/department with which the particular person is attached should initiate the proposal for the facility of Internet to be given to a particular person justifying the reason.
- 2.2. Routing - The proposal must be routed through Unit Head (State Head/Regional Head/Refinery Head and in case of HO/HQ it is to be routed through Functional ED) and Unit IS Head, who will be examining the necessity before forwarding it to Divisional HO for approval.
- 2.3. Approval – The requirement to be examined and approved by Divisional HR Head.
- 2.4. Validity – Till the end of ongoing financial year (31/03). Renewal to be done every year for a period valid up to end of next FY or the specific job requirement, whichever is earlier. Requirement to be assessed every time during renewal for applicability of the facility.
- 2.5. Revocation – Immediately on change of department and/or change of job responsibility and/or function the facility shall cease to exist. The department/function where the employee had been attached (at the time of transfer or change of responsibility) must intimate the change to HR and IS for withdrawal of the facility.

Approving Authority Table (Staff : Non-officers IOCL Employee)

For Users of	Forwarding Authority in Functional Dept.	Forwarding Authority in IS	Forwarding Unit Head	Approving Authority of HR Dept.
Corporate Office	Officer (Grade 'H' or above)	Divisional IS Head (Refineries)	Functional ED	HR Head, CO
COIS		COIS Head	COIS Head	HR Head, CO
IIPM/BD		IS Head	Functional ED	HR Head, CO
Divisional HQs.		Divisional IS Head	Functional ED	HR Head of respective division
Other offices/ location		IS Head (Refinery /	Unit Head (State	HR Head of respective



		State Office/ Regional Office/ Business Dev. / IIPM)	Head/Regional Head/Refinery Head	division
--	--	--	-------------------------------------	----------

Complete process from initiation to approval shall be accomplished through electronic format (e-approval). Application/approval form shall be uniform across all Divisions.

Annexure-C: Official E-mail Facility



CORPORATE OFFICE - HR INTER OFFICE MEMO

Ref.: DP/3/12/43	
Date: 29.06.2022	
From: CO (HR), New Delhi	
To : ED I/c (HR), Mktg. HO, Mumbai ED I/c (HR), Ref.-HO, New Delhi ED (HR), PL-HO, Noida CGM (HR), R&D Centre, Faridabad	

Sub: Official e-mail facility

- 1.0 As per extant policy, official e-mail account of the employee gets closed immediately at the time of separation.
- 2.0 Upon review, it has been decided that post separation, the facility of receiving e-mails on the official e-mail account may be extended to all officers separating on account of superannuation and VRS as per following modalities:
 - 2.1 At the time of filling Superannuation/VRS related forms, the officer shall be given the option to receive e-mails on his/her official e-mail account for a maximum of next 03 months from the date of separation. Upon opting for the same, the officer has to submit his/her personal e-mail account, on which all the e-mails received on the official e-mail account shall be forwarded.
 - 2.2 After separation, the officer shall not be able to access his/her official e-mail account. However, any e-mail received on the official e-mail account shall be forwarded by the system to the personal e-mail id of the concerned officer.

Additionally, a system generated e-mail shall also be sent to the sender stating that the concerned officer has superannuated from the services of IOCL alongwith details of the personal e-mail account of the officer.
- 3.0 The extant provision, as mentioned at point 1.0 above, shall continue to be extended for all other modes of separation.


(Awadhesh Mishra)
GM (HR)

cc: ED (IS) – CO, CBTC

Annexure-D: Aadhaar Compliance and Security

Document Version Control

Document Title	Guidelines for Aadhaar Enabled Applications
Effective Date	1 st September 2025
Review Frequency	Annually, or per statutory updates

Version History

Version	Date	Changes	Initiated By	Reviewed By
1.0	01-Sep-2025	Initial release	Sumit Kumar Rawat Sr. Manager (SDMS-CRM)	Sudip Deb Roy General Manager (IS)

This annexure outlines the policies, procedures, and requirements that all IndianOil's systems and applications utilizing Aadhaar must adhere to. Compliance with this annexure ensures alignment with the Aadhaar (Targeted Delivery of Financial and Other Subsidies, Benefits, and Services) Act, 2016, the Digital Personal Data Protection Act (DPDP Act), UIDAI regulations, and any statutory mandates from government or regulatory bodies.

1. Aadhaar Security Awareness and Training

Application User Group (AUG) will conduct Aadhaar security awareness training at least twice annually for designated MPOC (Main Point of Contact) and TPOC (Technical Point of Contact) personnel. MPOC and TPOC must remain updated on current UIDAI guidelines and regulatory standards.

2. Developer Training on Secure Coding Practices

Aadhaar application developers will undergo secure coding practices training semi-annually, with additional sessions when new security vulnerabilities arise, to stay current with best practices in data protection and secure application development.

3. Information Security and Data Privacy Training

Application Users, including Operators (such as LPG Delivery Partners), Sub-AUAs, and Sub-KUAs, must receive bi-annual training on Aadhaar-related data security and privacy. Specialized sessions will address role-specific guidelines in accordance with UIDAI standards and the Aadhaar Act.

4. Aadhaar Data Flow Diagram Maintenance

Application Development Team will maintain a version-controlled, management-approved Aadhaar data flow diagram that will be reviewed and updated annually to ensure accuracy and regulatory compliance.

5. Application Design Architecture Compliance

Application Development Team will develop and maintain a version-controlled application design architecture that incorporates all UIDAI security requirements. This architecture will undergo an annual review and will be updated and re-approved by management as necessary.

6. Static and Dynamic Application Security Testing (SAST and DAST)

Application Development Team should use & integrate SAST and DAST process into all Aadhaar-related application development processes. These tests will be conducted semi-annually and for each major development project to ensure adherence to security standards, with prompt issue remediation.

7. Integration with Identity and Access Management (IDAM)

AUA/KUA applications should integrate with Identity and Access Management, Privileged Identity/Access Management, and Security Information and Event Management systems, with periodic access event logging and review for security compliance.

8. Secure Development Lifecycle with Risk Assessment

Application User Group(AUG) will perform regular risk assessments and incorporate secure coding practices. Documentation of these processes will be reviewed every six months to maintain ongoing compliance.

9. Access Control Matrix Management

An access control matrix outlining user roles, access authorizations, and permissions will be maintained and reviewed semi-annually. Privileged access will be reviewed quarterly to ensure the accuracy of access controls, with management re-approval required for each update.

10. Revocation of Access for Exiting Personnel

Access to Aadhaar-related systems must be revoked within 24 hours for personnel exiting the organization, followed by prompt user ID deletion if no longer in use, thereby safeguarding data integrity.

11. Cross-Origin Resource Sharing (CORS) Compliance for APIs

Application Development Team will maintain a record of APIs with CORS configurations and update settings to restrict access to authorized domains only, performing testing post-updates to verify compliance.

12. Compliance with OWASP and Other Vulnerability Standards

The audit scope for all applications will encompass OWASP Top 10 and Other vulnerabilities, with structured timelines for vulnerability resolution to maintain high security standards.

13. Fraud Detection and Prevention Measures

Application Development Team will continuously review authentication logs and enhance fraud detection measures in line with ISO 27001 and NIST standards. This includes documentation of best practices, software tools, and analytic approaches.

14. Biometric Device Management and Tracking

A centralized repository will be maintained to document all biometric devices, including device details and ownership, with periodic reviews to ensure only registered devices are functional.

15. Chief Information Security Officer (CISO) Responsibilities

The organization shall ensure that all relevant documentation, including the organizational chart, job descriptions, and policy documents, is duly approved and signed, clearly delineating the role and

responsibilities of the Chief Information Security Officer (CISO). The CISO will be entrusted with the oversight of the organization's information security policies, IT risk management frameworks, and regulatory compliance to ensure the ongoing robustness of the organization's IT security posture.

16. Third-Party Information Security SOP

A SOP will be maintained to outline IT security standards for all third-party engagements, including vendors, suppliers, and service providers, to ensure adherence to IndianOil's IT security and regulatory requirements.

17. Data Protection Policy

Application User Group (AUG) will adhere to the Aadhaar Act, DPDP Act, and the Information Technology Act, 2000. Upon the DPDP Act's enactment, compliance with its provisions and rules will be ensured.

19. Encryption of Aadhaar Data

Strong encryption methods will be applied to Aadhaar data at rest and in transit, following industry-standard encryption algorithms to protect against unauthorized access and data breaches.

20. Incident Management and Root Cause Analysis (RCA)

A robust incident management framework will be maintained, with RCA for major incidents involving IndianOil or its subcontractors, following UIDAI guidelines for continuous improvement.

21. Privacy Incident Reporting

Privacy incidents must be reported to affected individuals and UIDAI within 24 hours, ensuring regulatory compliance and enabling timely investigation and remediation.

22. Patch Management Policy

IndianOil will implement a patch management policy to monitor and apply security patches promptly, maintaining system integrity through a documented process.

23. Operator Background Verification

Background checks will be required for all operators performing Aadhaar authentication functions to ensure integrity and trustworthiness.

24. Asset Hardening and Security Baseline

All assets used for Aadhaar Authentication must undergo hardening to mitigate vulnerabilities before deployment.

25. Aadhaar Authentication Asset Security and Hardening Policy

Respective Group will ensure that all assets utilized for Aadhaar Authentication, including desktops, laptops, servers, and databases, undergo a thorough hardening process in accordance with the organization's established hardening baseline standards. These assets will be secured to mitigate vulnerabilities and strengthen their security posture, ensuring they are fully secure before deployment and operational use.

Periodic Review and Amendment

This annexure is subject to review annually and will be updated as and when necessary to remain compliant with regulatory changes, statutory requirements, or any new guidance issued by the UIDAI or other government authorities. Amendments will be made promptly following changes to the Aadhaar (Targeted Delivery of Financial and Other Subsidies, Benefits, and Services) Act, 2016, Digital Personal Data Protection Act (DPDP Act), or other relevant policies.